

Zero Trust Road Map

Instruction

Based on your analysis of the company profile, provide **one (1)** proposed safeguard (control) that can be implemented to address **each** of the five pillars of the zero trust architecture: **Identity, Device, Network, Application Workflow, and Data**.

- For each of the recommended safeguards, briefly describe or justify your recommendation (1-2 sentences).
- Then, describe at least three (3) anticipated prerequisite capabilities, assumptions, or challenges that the company must implement in order to realize this objective.

Based on your analysis of the company profile, provide **one (1)** foundational capability that the company can deploy to support a zero trust architecture.

- For this foundational capability, briefly describe or justify your recommendation (1-2 sentences).
- Then, describe at least three (3) anticipated prerequisite capabilities, assumptions, or challenges that the company must implement in order to realize this objective.

<i>Example: Zero Trust Pillar - Identity</i>	
Proposed Safeguard	<i>Passwordless Authentication</i> <i>Passwordless authentication strategy will mitigate the risk of attacks from social engineering, phishing, and brute-force guessing attacks that lead to compromised credentials.</i> <i>We can possibly implement passwordless authentication to manage access to our organization's workstations, internally-facing web applications, and anywhere this is supported as an alternative to traditional password authentication.</i>
Prerequisites, Assumptions, Challenges	<i>1. In order to roll out passwordless authentication to the environment, we will need to ensure that everyone in the organization, including contractors, has access to an approved authentication factor such as a FIDO2 hardware token or authenticator app.</i> <i>2. We may need a roll-out plan to provide FIDO2 tokens to people who do not have access to a phone capable of utilizing the authenticator app, and to support this, we will need procedures to distribute and activate those tokens.</i>

3. *We will need to plan a series of communications to inform the users that they will need to register their authentication factor with our organization, and we will need to set a cut-off date for people to enroll their device to ensure that they do not experience a lapse in service.*

Zero Trust Pillar - Identity

Proposed Safeguard	<i>MFA (Multi-Factor Authentication)</i> <i>Will enable the authentication method to be more accurate by multiplying the number of login based either on biometric-data or to 'other' factors unrelated to the password-username login. This will result in a dampened risk when credentials are stolen and will result in a more effective sanitization of the employee id.</i>
Prerequisites, Assumptions, Challenges	1. <i>Audit OpenLDAP to ensure that stale accounts are correctly deleted and disposed.</i> 2. <i>Define roles for the various employee groups and define priority, and access level for each role and function.</i> 3. <i>Implement the MFA, but paying attention to not rely on personal devices which are prohibited by the policy. An external key might be needed for this process, in this step it is important to define this feature and distribute it across the employees if needed.</i>

Zero Trust Pillar - Device

Proposed Safeguard	<i>MDM (Mobile Device Management)</i> <i>Establishing a software version that allows to track the Corporate owned devices and does not allow them to exit a designated production area, this would significantly improve the distinction between personal devices and work devices in common areas, diminishing the risk of a data leak. Also, a good MDM software would ensure that the device is healthy and connected only where it matters, when it matters, and within compliant frameworks.</i>
Prerequisites, Assumptions, Challenges	1. <i>Establishing a secure baseline based on a Hardware inventory.</i> 2. <i>Issuing a Device Certificate so the network can distinguish between a personal device and a corporate owned one.</i> 3. <i>Install the software agent in all of the devices so that its report can be transmitted to the Policy Engine.</i>

Zero Trust Pillar - Network

Proposed Safeguard	<i>Network microsegmentation</i> <i>The network is still depicted as a plain landscape easily navigable by a threat actor, in which case microsegmenting it further would enhance the possibility of the TA getting lost in the maze of our infrastructure, or losing the access due expired credentials before being able to figure out how to move and exploit the network.</i>
Prerequisites, Assumptions, Challenges	<i>1. Before starting to segment the network is fundamental to deploy monitoring tools to establish a baseline in the communication systems, traffic patterns between the CRM, ERP, and File Server must be clearly visible.</i> <i>2. A complete inventory of all the devices owned, and subsequent tagging to make sure the Firewall knows how to treat each one of them.</i> <i>3. Replacement of hardware for updates may be required if not compatible with the measure implemented.</i>

Zero Trust Pillar - Application Workload

Proposed Safeguard	<i>Session Control</i> <i>Since the CRM system is hosted on-premise and is only accessible from the company network, adding rules to prevent certain types of actions, or timeouts to request a new authentication would reduce the amount of actions against the system an attacker could hope to accomplish in a specified timeframe.</i>
Prerequisites, Assumptions, Challenges	<i>1. Application mapping and dependency discovery to avoid its own session controls to accidentally shut down the integration that allows the customer to pay invoices.</i> <i>2. It is important to define what triggers the re-authentication event.</i> <i>3. Implementing a Secure Proxy or Access Gateway to stay in front of the on premise CRM. To act as an enforcement point that verifies the device identity and health before a user is allowed to see the CRM page.</i>

Zero Trust Pillar - Data

Proposed Safeguard	<i>DLP (Data Loss Prevention)</i> <i>A DLP tool would minimize the possibility of data exfiltration by setting a control over the confidential information that is within the Local File Server. The tool would detect</i>
--------------------	--

	<i>any attempt to transfer data or download files, and would trigger an alarm in case these actions are performed without the proper authorization as per protocol.</i>
Prerequisites, Assumptions, Challenges	1. <i>Setting up a data discovery and classification campaign to allow the DLP Software to recognize which data should it protect and how.</i> 2. <i>Establishing the rules that the DLP Software must follow.</i> 3. <i>Establishing Data Encryption Standards for both data at rest and data in transit. So that even if unauthorized access occurs the unstructured data remains unreadable.</i>

Zero Trust Foundation

Proposed Capability	<i>Governance: Policies and Procedures</i> <i>Governance provides the centralized set of rules and compliance standards that dictate how the pillars interact, ensuring that 'Never Trust, Always Verify' is a legal and operational requirement for all employees and contractors.</i>
Prerequisites, Assumptions, Challenges	1. <i>To be very careful with the frictions of transitioning from a very relaxed environment, to one where every access is observed, avoiding the downsides in the morale and good disposition of the team.</i> 2. <i>Breaching the gap between the transition from a legacy system to a more new cloud based one, using a hybrid-policy approach.</i> 3. <i>Ensuring that the third-party contractors do in fact, agree to make and comply with these changes promoted based on ZTA. A negotiation might be necessary.</i>